Politechnika Krakowska
im. Tadeusza Kościuszki

Wydział Informatyki i Matematyki

Wiktor Zmiendak

Numer albumu: 142706

Sprawozdanie

Wykrywanie zagrożeń i reakcji na incydenty

Laboratorium nr 2

Przebieg ataku:

Celem laboratorium było przeanalizowanie zarejestrowanego przez Snort NIDS incydentu do którego doszło na przełomie stycznia 2017.

Można powiedzieć, że do ataku doszło w sposób gwałtowny. Z przeanalizowanych alertów w Kibanie wynika, że jego destynacja to Rosja, a sama aktywność została sklasyfikowana jako trojan. Sprawdzając sygnaturę alertu dowiadujemy się, że nasz malware jest typu Exploit_Kit_RIG co oznacza, że wykorzystuje on liczne przekierowania zwykle na pozornie bezpiecznych stronach internetowych w celu zainfekowania złośliwym oprogramowaniem.

Dzięki transkrypcji capMe docieramy do informacji, że pierwotną stroną na którą chciał się dostać użytkownik było www.homeimprovement.com jednak został on przekierowany do tyu.benme.com, gdzie zapytanie GET pobrało szkodliwy malware zapakowany w paczce gzip. Dodatkowo ograniczając nasze poszukiwania do paru minut od rozpoczęcia ataku możemy zauważyć inne podejrzane strony na które został przekierowany użytkownik (np. p27dokhpz2n7nvgr.1jw2lx.top, spotsbill.com).

Przechodząc do analizy w Sguil potwierdzamy tutaj nasze ustalenia dotyczące malwaru typu trojan oraz tego, że został on pobrany poprzez przekierowanie na podejrzaną stronę. W jednym z alertów możemy znaleźć serię zapytań skutkujących pobraniem pliku o sygnaturze CWS, a więc pliku Adobe Flash. Sprawdzając kolejne alerty widzimy, podobny schemat operacyjny kończący się pobraniem owego pliku.

Ekstraktując hash z podejrzanych plików flash pochodzących z dwóch różnych alertów, a następnie sprawdzając je na stronie virustotal możemy dowiedzieć się, że większość znanych antywirusów rozpoznaje je jako szkodliwy exploit.

Sprawdzając jeszcze ostatnie alerty dotyczące ataku widzimy próbuję dostania się do podejrzanej domeny p27dokhpz2n7nvgr.1jw2lx.top. Jest to o tyle dziwne, że request wychodzi od użytkownika co może sugerować działanie pobranego wcześniej malwaru.

Na koniec analizujemy kod strony na której doszło do ataku. W jednym z tagów widzimy załadowanie pliku dle_js.js. Po jego odnalezieniu widzimy, że posiada zniekształcony tag prawdopodobnie w celu uniknięcia bycia wykrytym. Samo jego działanie polega na przekierowaniu pod wspomniane już tyu.benme.com.